

Security Groups

Stateful, Allow-Only Virtual Firewalls at the Instance Edge

Interview Preparation Guide

Problem & motivation - statefulness - SG referencing/chaining - packet flow - failure modes - scaling - security - observability & automation - cost - troubleshooting - real-world patterns

Table of Contents

1. The Problem It Solves	3
2. How It Works Internally	3
3. Traffic Flow, Packet Flow & Routing Decisions	4
4. Advantages & Disadvantages	4
5. Common Failure Modes	5
6. Scaling Considerations	5
7. Security Implications	5
8. Observability, Reliability & Automation	5
9. Cost Considerations	6
10. Troubleshooting Approach	6
11. Real-World Examples & Patterns	6
12. Senior-Level Trade-offs & Talking Points	7
13. Quick Glossary	7

Executive Summary

A security group (SG) is a stateful, instance-level virtual firewall attached to elastic network interfaces. It contains allow-only rules; there is no explicit deny. Because it is stateful, response traffic for an allowed flow is permitted automatically, so you never write return rules. The standout feature is that rule sources/destinations can be OTHER security groups, enabling identity-based, self-updating microsegmentation. SGs are the primary, most-used network control in a VPC. This guide covers internals, packet flow, failure modes, scaling, security, observability, automation, cost, and troubleshooting.

1. The Problem It Solves

Workloads need least-privilege network access that follows the resource, not the subnet, and that updates automatically as fleets scale up and down. Security groups provide per-ENI, identity-aware allow rules that are simple to reason about and stateful by default.

Core needs security groups address

- **Least privilege:** Open only the exact ports/sources each resource needs.
- **Statefulness:** Permit return traffic automatically - no error-prone ephemeral-port rules.
- **Identity-based rules:** Reference other SGs so rules track dynamic, autoscaling fleets without IP churn.
- **Per-resource scope:** Controls travel with the ENI regardless of subnet.

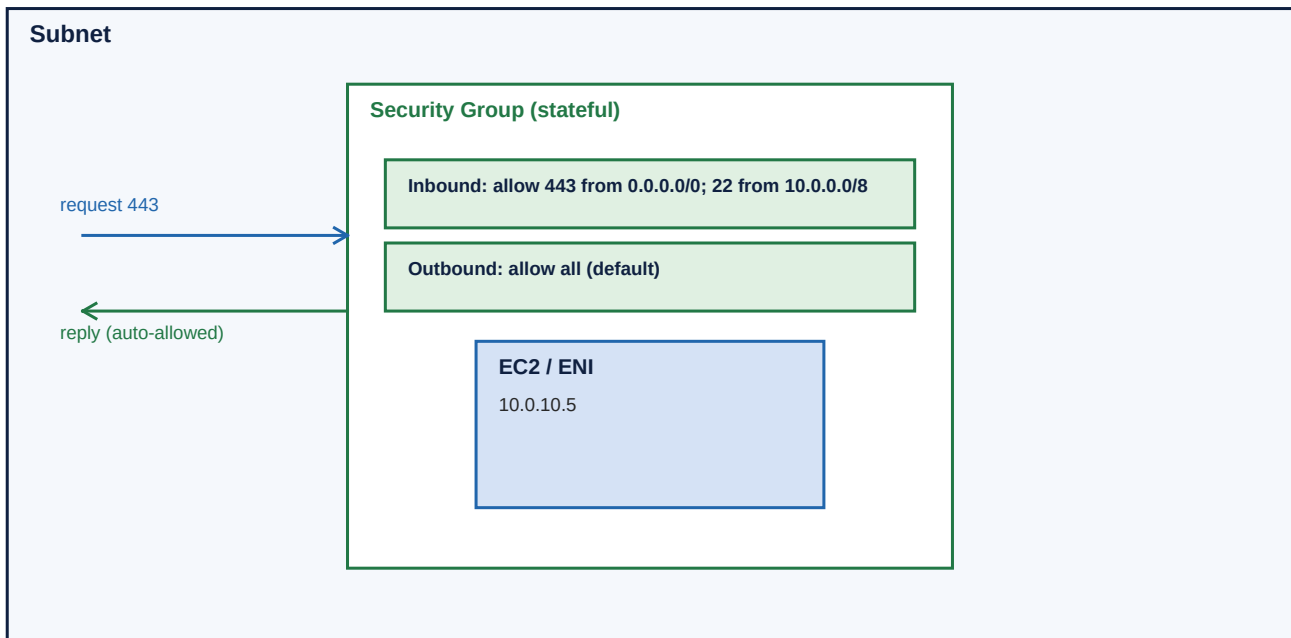
2. How It Works Internally

A security group is evaluated in the data plane (in AWS Nitro/host hardware) for every packet to/from the ENIs it is attached to. It holds two rule sets - inbound and outbound - each a list of allow rules keyed by protocol, port range, and source/destination (CIDR, another SG, or a prefix list). There is no deny rule and no rule ordering; if any rule allows the packet it is permitted.

- Stateful connection tracking: an allowed outbound flow's replies are auto-allowed inbound, and vice versa.
- Defaults: deny all inbound, allow all outbound (until you tighten it).
- Up to several SGs can attach to one ENI; their allow rules are unioned.
- Referencing another SG (e.g., 'allow from sg-app') auto-includes all current members of that SG - no IP lists to maintain.

Reference Diagram - Stateful security group around an ENI

A security group is a stateful, allow-only virtual firewall attached to elastic network interfaces. Because it is stateful, any flow you allow OUT is automatically allowed back IN (and vice versa) - you never write return rules.



Rules are allow-only (no explicit deny). Default inbound = deny all; default outbound = allow all. Sources can be CIDRs or OTHER security groups (chaining), e.g., allow the app SG to reach the DB SG on 5432.

3. Traffic Flow, Packet Flow & Routing Decisions

How SGs participate in a flow

- Inbound packet to an ENI: the union of that ENI's SG inbound rules is checked; if allowed, accepted.
- Because SGs are stateful, the response leaves without needing an explicit outbound rule.
- Outbound-initiated flows: outbound rules checked; responses auto-allowed inbound.
- SGs do not affect routing - routing is the route table's job; SGs only permit/deny.

Stateful vs stateless

Unlike NACLs (stateless), SGs track connection state, so you only define the direction that INITIATES a connection. This eliminates the classic ephemeral-port mistake.

4. Advantages & Disadvantages

Advantages

- Stateful - simple, fewer mistakes.
- Identity-based via SG referencing - scales with dynamic fleets.
- Per-ENI granularity that follows the workload.
- Enforced in hardware at line rate.

Disadvantages / costs

- Allow-only: cannot express an explicit deny/blocklist (use NACLs/firewall).
- Rule and SG-per-ENI quotas can constrain very complex policies.
- Over-broad rules (0.0.0.0/0 on sensitive ports) are a common risk.
- No central ordering/priority - reasoning about large rule sets gets hard.

5. Common Failure Modes

Failure	Symptom	Typical root cause
Missing inbound allow	Connection refused/timeout	Required port/source not permitted inbound.
Tightened egress	Outbound app calls fail	Default allow-all egress replaced without needed allows.
Wrong SG attached	Unexpected exposure/block	ENI has the wrong SG set.
Over-broad rule	Security exposure	0.0.0.0/0 on 22/3389/db ports.
SG-reference confusion	Cross-SG flow blocked	Rule references the wrong SG, or peering needs CIDR not SG-ref.
Quota exceeded	Cannot add rule/SG	Hit rules-per-SG or SGs-per-ENI limits.

6. Scaling Considerations

- **Reference, don't enumerate:** Use SG-to-SG rules instead of long IP lists so policy scales with autoscaling.
- **Prefix lists:** Group common CIDRs into managed prefix lists referenced by many SGs.
- **Tiered SGs:** One SG per role (web/app/db) and chain them rather than per-instance SGs.
- **Quotas:** Watch rules-per-SG and SGs-per-ENI; request increases for complex environments.
- **Cross-VPC caveat:** SG referencing works within a VPC/peered-and-enabled contexts; across boundaries you may need CIDRs.

7. Security Implications

- Default deny inbound; open the minimum necessary.
- Prefer SG references over wide CIDRs for east-west traffic.
- Never expose management ports (22/3389) to 0.0.0.0/0 - use SSM/bastion.
- Tighten egress for sensitive tiers to curb exfiltration and lateral movement.
- Treat SGs as code; review every change.

8. Observability, Reliability & Automation

Observability

- Flow Logs show REJECT entries when an SG/NACL blocks a flow.
- Reachability Analyzer pinpoints which SG rule is missing/blocking.
- Config rules to flag over-permissive SGs (e.g., open 22).

Reliability

- SGs are enforced per-ENI in HA hardware; reliability is about correct rules.
- Avoid 'fix by opening 0/0' - it trades an outage for an exposure.

Automation

- Define SGs + rules in IaC; use SG references for dynamic membership.
- Policy-as-code/Config to detect and auto-remediate risky rules.

9. Cost Considerations

Cost driver	Why it adds up	Mitigation
Security groups	Free - no charge for SGs or rules.	N/A; cost is operational (managing rule sprawl).
Rule sprawl	Indirect cost: errors, audits, incidents.	SG referencing + prefix lists to keep rules minimal.
Blocked-traffic debugging	Engineer time on misconfig.	Reachability Analyzer + Flow Logs to cut MTTR.

10. Troubleshooting Approach

For 'cannot connect to a resource':

- 1. Which SGs are on the TARGET ENI, and do their INBOUND rules allow the source + port?
- 2. Does the SOURCE's OUTBOUND allow it (if egress was tightened)?
- 3. If using SG references, is the right SG referenced (and same VPC)?
- 4. Remember SGs are stateful - don't chase return rules; check NACLs for those.
- 5. Use Reachability Analyzer + Flow Log REJECTs.

Mnemonic

'Target inbound -> Source outbound -> SG reference.' Statefulness means return traffic is not your problem here - that's a NACL concern.

11. Real-World Examples & Patterns

- **Tiered chaining:** web SG allows 443 from internet; app SG allows from web SG; db SG allows 5432 from app SG.
- **Bastion-free admin:** No SSH SG to the world; use SSM Session Manager instead.
- **Shared services:** Reference a central 'monitoring' SG to permit scraping across fleets.
- **Microsegmentation:** Per-microservice SGs referencing each other for least-privilege east-west traffic.

12. Senior-Level Trade-offs & Talking Points

- SG references (dynamic, scalable) vs CIDR rules (work across boundaries).
- Few broad SGs (simple) vs many fine SGs (least privilege, more management).
- SGs (stateful allow-only) vs NACLs (stateless allow/deny) - use both as layers.
- Tightening egress (security) vs operational friction (breaking app calls).

Whiteboard checklist

(1) Draw ENI wrapped by SG. (2) Show inbound allow + stateful return. (3) Chain web->app->db via SG references. (4) Note default deny-in/allow-out. (5) Contrast with NACLs. (6) Discuss SG-ref scaling and exposure risks.

13. Quick Glossary

Term	Meaning
Security group	Stateful, allow-only firewall on an ENI.
Stateful	Return traffic for allowed flows is auto-permitted.
SG reference	A rule whose source/dest is another security group.
Inbound/Outbound rules	Separate allow lists per direction.
Default SG	Allows all intra-SG traffic; deny-in/allow-out otherwise.
Prefix list	Named, reusable set of CIDRs usable in SG rules.
ENI	Elastic Network Interface the SG attaches to.